F FWallSim · Firewall Course

CLASS 8

Harden administrative access

Admin profiles, trusted hosts, local-in policy

Intermediate | ~20 minutes | FWallSim v1.0.0 (FortiOS 7.4 style)

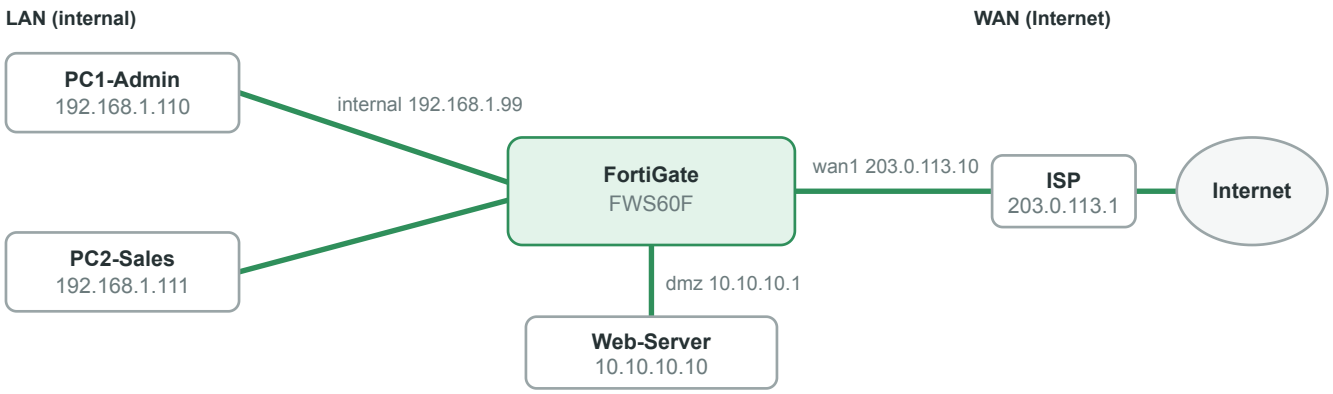
YOU WILL LEARN

- Admin profiles
- trusted hosts
- local-in policy

BEFORE YOU START

Finish Class 7 first.

The lab network



The goal

THE IDEA

HTTPS and SSH admin access are open on wan1 to the whole internet. Lock it down: an auditor account limited to the LAN, admin HTTPS only from the office IP (Internet-User, 198.51.100.77), and no SSH from outside.

How to start

1. Open FWallSim and log in.
2. Click **Labs** in the header.
3. Find **Harden administrative access** and click **Start**.
4. The Lab Guide panel opens. Each task below gets a green tick as soon as it works.

Tasks

1. **Create admin "auditor" with a profile that can change nothing**

   System > Admin Profiles > Create New (set all to Read), then System > Administrators > Create New "auditor" with that profile.

2. **auditor may only log in from the LAN (192.168.1.0/24)**

   Edit auditor > Restrict login to trusted hosts > 192.168.1.0/24.

3. **Admin HTTPS on wan1: office yes, Attacker no**

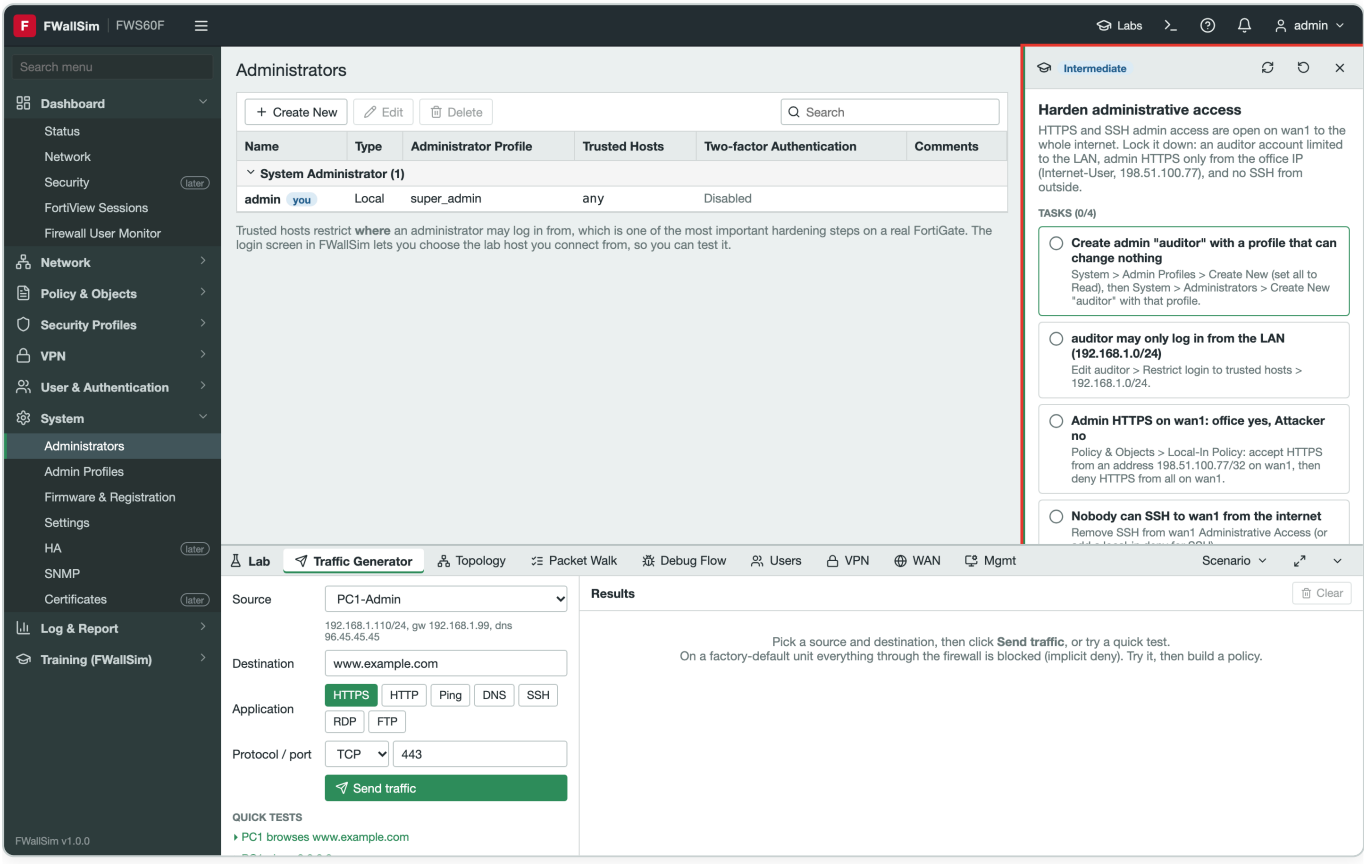
   Policy & Objects > Local-In Policy: accept HTTPS from an address 198.51.100.77/32 on wan1, then deny HTTPS from all on wan1.

4. **Nobody can SSH to wan1 from the internet**

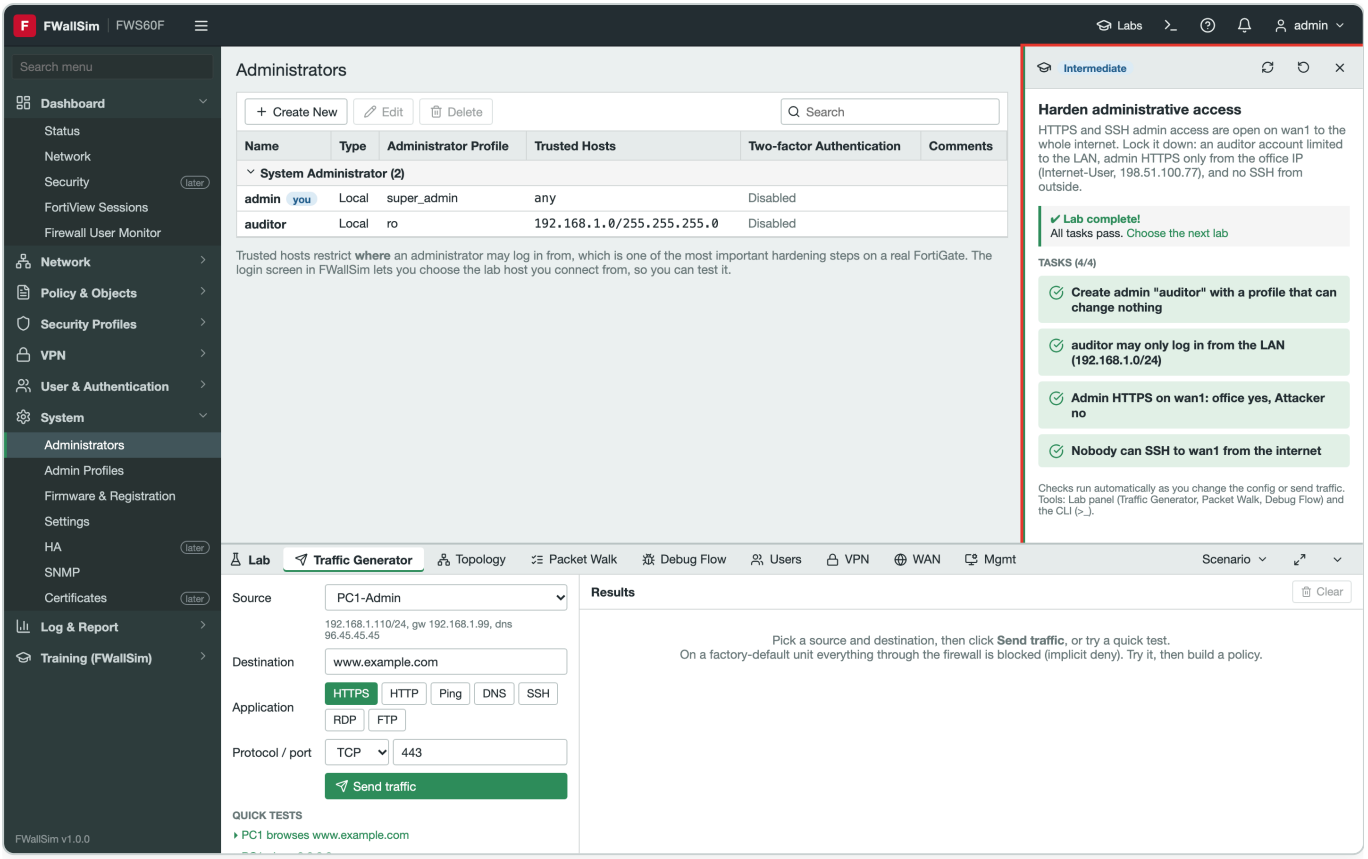
   Remove SSH from wan1 Administrative Access (or add a local-in deny for SSH).

Screenshots

Numbered red markers show where to click or what to look at.



Lab Started



Lab Solved

Admin Profiles

+ Create New | Edit | Delete | Search

Name	Security Fabric	FortiView	User & Device	Firewall	Log & Report	Network	System	Security Profile	VP
prof_admin	RW	RW	RW	RW	RW	RW	R	RW	R
super_admin	RW	RW	RW	RW	RW	RW	RW	RW	R
ro	R	R	R	R	R	R	R	R	R

A profile decides what an administrator may see (Read) and change (Read/Write) in each area. Areas set to None disappear from that administrator's menu.

Admin Profiles

Administrators

+ Create New | Edit | Delete | Search

Name	Type	Administrator Profile	Trusted Hosts	Two-factor Authentication	Comments
System Administrator (2)					
admin you	Local	super_admin	any	Disabled	
auditor	Local	ro	192.168.1.0/255.255.255.0	Disabled	

Trusted hosts restrict **where** an administrator may log in from, which is one of the most important hardening steps on a real FortiGate. The login screen in FWallSim lets you choose the lab host you connect from, so you can test it.

Administrators

Local-In Policy

+ Create New | Edit | Delete | Search

ID	Interface	Source	Destination	Service	Action	Comments
1	wan1	Office	all	HTTPS	✓ ACCEPT	
2	wan1	all	all	HTTPS	⊘ DENY	

Local-in policies control traffic **to the FortiGate itself** (admin GUI, SSH, ping, SNMP). They are checked before Administrative Access. A typical use: HTTPS admin is enabled on wan1, then a local-in policy denies everyone except your office IP. Firewall policies never apply to this traffic.

Local In Policy

Next: Class 9: Identity-based access with LDAP